

Sandworm: 2022 Ukraine Electric Power Attack

A dual-domain operation combining native OT functionality with destructive enterprise activity

ACTOR	CAMPAIGN	OBSERVED	TARGET
Sandworm Team GRU Unit 74455	MITRE C0034 Enterprise + ICS	Jun-Oct 2022 Ukraine	Electric utility IT and SCADA

Executive assessment

Sandworm, a destructive threat group attributed to Russia's GRU Main Center for Special Technologies (GTsST), Military Unit 74455, compromised a Ukrainian electric utility and reached a MicroSCADA management environment. On 10 October 2022, the actor used a mounted ISO, scripts, and the legitimate `scilc.exe` utility to issue unauthorized control commands that likely tripped substation circuit breakers and caused an unscheduled outage. Two days later, Sandworm used TANKTRAP and Group Policy to distribute CaddyWiper across the IT environment.^{[1][2]}

KEY JUDGMENT | The defining risk was not custom ICS malware. Sandworm repurposed trusted, native SCADA functionality, reducing its footprint and making malicious activity resemble legitimate engineering work.

Operational objectives	Analytic limitations
- Disrupt electrical operations through unauthorized SCADA commands. - Degrade IT availability using destructive malware. - Potentially hinder recovery and remove forensic evidence.	- The initial access vector was not recovered. - The exact SCIL command file was unavailable. - Some intent is assessed from effects; not all artifacts survived anti-forensic activity.

Attack sequence

JUN	Foothold	Neo-REGEOG web shell observed on an internet-facing server.
JUL	Persistence + C2	GOGETTER deployed as a masqueraded systemd service; Yamux traffic tunneled over TLS.
JUN-OCT	OT access	Adversary reached the hypervisor hosting the MicroSCADA management instance.
10 OCT	OT disruption	<code>a.iso</code> autoran VBS/batch files; <code>scilc.exe</code> issued likely breaker commands.
12 OCT	IT destruction	TANKTRAP used GPO file-copy and scheduled-task policies to execute CaddyWiper.

MITRE ATT&CK mapping - Enterprise

All Enterprise techniques from the original brief are retained. Domain and tactic labels below follow the current ATT&CK taxonomy; a technique may support multiple tactics. The initial access technique remains unknown and is therefore not assigned an ATT&CK ID.^[2]

ID	Technique	Tactic(s)	Observed use
T1059.001	PowerShell	Execution	TANKTRAP used PowerShell to spread and launch the wiper through Group Policy.
T1053.005	Scheduled Task	Execution; Persistence; Privilege Escalation	GPO-created tasks executed CaddyWiper at predetermined times.
T1543.002	Systemd Service	Persistence; Privilege Escalation	A systemd unit started GOGETTER at boot and maintained access.
T1505.003	Web Shell	Persistence	Neo-REGEORG was placed on an internet-facing server.
T1484.001	Group Policy Modification	Defense Impairment; Privilege Escalation	GPOs copied and executed malware across domain systems.
T1036.004	Masquerade Task or Service	Stealth	GOGETTER systemd units were named to appear legitimate.
T1570	Lateral Tool Transfer	Lateral Movement	A GPO copied msserver.exe from staging to local disks.
T1095	Non-Application Layer Protocol	Command and Control	C2 communications were proxied inside a TLS-based tunnel.
T1572	Protocol Tunneling	Command and Control	GOGETTER created a Yamux-based C2 channel over TLS.
T1485	Data Destruction	Impact	CaddyWiper targeted files, mapped drives, and physical drive partitions.

Enterprise detection priorities

Signal	What to correlate	Why it matters
GPO changes	Directory changes + SYSVOL file writes + scheduled-task creation	Identifies centralized malware distribution and timed execution.
PowerShell	Script block logs + process ancestry + remote file copies	Distinguishes administrative automation from TANKTRAP-like deployment.
Linux services	New/modified unit files + systemctl activity + unusual ExecStart paths	Detects persistent tunnelers and service masquerading.
Web servers	New server-side scripts + anomalous requests + child processes	Surfaces Neo-REGEORG-like persistence on exposed systems.
Encrypted C2	New long-lived TLS sessions + rare destinations + host process context	Reveals tunneling even when payload content is unavailable.
Wiper staging	Remote executable copies + scheduled execution + rapid file/drive writes	Provides the last opportunity to interrupt destructive impact.

COLLECTION NOTE | Enable PowerShell script-block logging, Windows process creation with command lines, Directory Service/SYSVOL auditing, scheduled-task telemetry, Linux service auditing, and web-server logs. Centralize records so activity can be correlated across the attack path.

MITRE ATT&CK mapping - ICS

The five ICS techniques from the original brief are retained and explicitly marked as ICS. The operation used trusted MicroSCADA components and an autorun-enabled virtual CD-ROM path to reach process control.^{[1][2]}

ID	Technique	Tactic(s)	Observed use
T0895	Autorun Image	Execution	Existing hypervisor access mapped a.iso to the SCADA VM; CD-ROM autorun launched the embedded VBS script.
T0807	Command-Line Interface	Execution	The actor invoked the MicroSCADA SCIL-API through scilc.exe.
T0853	Scripting	Execution	lun.vbs ran n.bat, which likely invoked scilc.exe.
T0894	System Binary Proxy Execution	Evasion	The trusted MicroSCADA binary proxied attacker-defined SCIL instructions to substations.
T1692.001	Unauthorized Message: Command Message	Evasion; Impair Process Control	The SCIL-API sent unauthorized operational commands to substation devices.

Tools and operational artifacts

Name	Role	Environment	Defender relevance
Neo-REGEORG	Web shell	Enterprise	Persistent access through an exposed server; monitor file creation and anomalous web requests.
GOGETTER	Golang tunneler	Enterprise	Yamux-over-TLS C2 with systemd persistence and service masquerading.
TANKTRAP	PowerShell deployment utility	Enterprise	Abused GPO file copy and scheduled tasks to deploy a wiper at scale.
CaddyWiper	Destructive wiper	Enterprise	Executed as msserver.exe; targeted files, mapped drives, and partitions.
a.iso	Delivery container	ICS	Mounted as a virtual CD-ROM to trigger autorun on the SCADA server.
lun.vbs / n.bat	Script chain	ICS	Bridged autorun execution to the native SCIL command utility.
scilc.exe / s1.txt	Native utility + command file	ICS	Likely issued attacker-defined SCIL commands to remote substations.

Highest-value OT detections

Host and application telemetry	Network and process telemetry
- Unexpected ISO mounting on SCADA hypervisors. - Autorun execution from virtual CD-ROM media. - New VBS, batch, SCIL, or text files on SCADA hosts. - scilc.exe -do outside approved engineering workflows.	- New or unexpected connections to controllers. - Command functions outside approved windows or operating states. - Native OT tools spawning from unusual parents or media. - Process changes without matching operator action or work orders.

Defensive priorities

Controls should prevent unauthorized administrative paths, constrain native OT execution, and preserve enough cross-domain telemetry to connect enterprise staging with physical-process effects.

Priority	Action	Security outcome
1 Segment	Separate IT, OT management, SCADA, and field-device zones; tightly govern hypervisor and jump-host access.	Limits movement from enterprise systems into process control.
2 Harden	Upgrade unsupported MicroSCADA; require authentication and least privilege; disable external SCIL-API execution where feasible.	Removes the exact native execution path abused in the incident.
3 Allowlist	Restrict which hosts, users, binaries, command arguments, and protocol functions may control field assets.	Blocks valid-looking commands from unauthorized contexts.
4 Monitor	Centralize AD/GPO, endpoint, hypervisor, SCADA application, network, and process-history telemetry.	Connects early enterprise behavior to later OT effects.
5 Prepare	Maintain offline recovery material and rehearse manual operations, domain recovery, and loss-of-view/loss-of-control scenarios.	Reduces outage duration and wiper-driven recovery risk.

Why this campaign matters

The operation demonstrates that an OT-capable adversary may not need purpose-built control-system malware. Knowledge of the target platform, access to an administrative layer, and a legitimate command utility can be enough to create physical impact. For defenders, the central question is therefore not only whether a binary is trusted, but whether its user, parent process, command arguments, destination, timing, and resulting process state are authorized.

EXECUTIVE TAKEAWAY | Treat the IT-to-OT administrative path as a critical control surface. Protect it with segmentation and least privilege, then detect deviations by correlating identity, host, network, OT-command, and physical-process telemetry.

Sources and methodology

Technique inventory preserved from the supplied brief and validated against MITRE ATT&CK campaign C0034. Enterprise/ICS domains and tactic names follow ATT&CK v19 as accessed 20 July 2026. Incident facts prioritize Mandiant's incident-response reporting; Dragos and U.S. Department of Justice reporting provide corroborating context. Confidence language is retained where the source reports an assessment rather than a confirmed fact.

[1] Mandiant, "Sandworm Disrupts Power in Ukraine Using a Novel Attack Against Operational Technology," 9 Nov. 2023. cloud.google.com/.../sandworm-disrupts-power-ukraine-operational-technology

[2] MITRE ATT&CK, "2022 Ukraine Electric Power Attack (C0034)," Enterprise and ICS Navigator layers. attack.mitre.org/campaigns/C0034/

[3] MITRE ATT&CK, "Sandworm Team (G0034)." attack.mitre.org/groups/G0034/

[4] Dragos, "ELECTRUM Targeted Ukrainian Electric Entity Using Custom Tools and CaddyWiper Malware, October 2022," 11 Dec. 2023. dragos.com/blog/new-details-electrum-ukraine-electric-sector-compromise-2022

[5] U.S. Department of Justice, "Six Russian GRU Officers Charged in Connection with Worldwide Deployment of Destructive Malware," 19 Oct. 2020. justice.gov/archives/opa/pr/six-russian-gru-officers-charged...

Prepared by	Josiah Rhee TAC Internship	Document type	APT / OT campaign brief
-------------	------------------------------	---------------	-------------------------